Báo cáo Kiểm thử: Feature C (Pool C) — FR-14: Quản lý Danh mục (Category CRUD)

Học phần: Kiểm thử Phần mềm (FIT-HCMUS)
Bài tập: HW02 – Domain Testing & Boundary Value Analysis on EShop
Tính năng kiểm thử: `FR-14: Category CRUD (Web Admin & Backend API)`
Kỹ thuật áp dụng: Phân hoạch tương đương (EP), Phân tích giá trị biên (BVA), Kiểm thử phân quyền truy cập (Access Control Domain)

---

1. Phân tích Đặc tả Yêu cầu & Xác định Biến (Identify Inputs & Outputs)

1.1 Căn cứ Đặc tả (SRS Ground Truth)

Theo tài liệu đặc tả hệ thống `EShop` (FR-12, FR-14, SEC-03):

1. **Quy tắc Nghiệp vụ Danh mục (FR-14):**
   - Admin có thể Thêm / Xem / Xóa danh mục.
   - **Tên danh mục là bắt buộc, không được để trống** ($length \ge 1$).
2. **Quy tắc Kiểm soát Truy cập (FR-12, SEC-03):**
   - Phân hệ Admin và các API có tính ảnh hưởng dữ liệu (`POST/PUT/DELETE /api/categories`) chỉ dành cho tài khoản có `role = 'admin'`.
   - Phải kiểm tra trường `role = 'admin'` bên trong Token JWT, không chỉ kiểm tra sự tồn tại của Token.

1.2 Danh sách Biến Đầu vào (Inputs) & Đầu ra (Outputs)

Tên biến	Kiểu dữ liệu	Ý nghĩa	Ràng buộc nghiệp vụ (Constraints)
`name`	String	Tên của danh mục	Bắt buộc, không để trống, $length \ge 1$, không chứa script độc hại
`id` (khi xóa/sửa)	Integer	ID của danh mục	Số nguyên dương, phải tồn tại trong CSDL
`auth_token`	JWT Token	Token xác thực người dùng	Bắt buộc phải có và phải có `role = 'admin'`

Kết quả đầu ra kỳ vọng (Outputs):

- **Output 1 (Thành công):** Danh mục được tạo/cập nhật/xóa trong CSDL, giao diện cập nhật danh sách.
- **Output 2 (Lỗi dữ liệu):** Từ chối khi `name` rỗng hoặc chỉ có khoảng trắng.
- **Output 3 (Lỗi phân quyền):** Trả về HTTP 403 Forbidden nếu người dùng không phải Admin.

---

2. Phân hoạch Lớp Tương đương (Equivalence Partitioning - EP)

Biến kiểm tra	Mã lớp	Mô tả lớp tương đương (Equivalence Class)	Phân loại
Tên danh mục (`name`)	**EC01**	Chuỗi ký tự hợp lệ ($1 \le length \le 255$, ví dụ: "Đồ điện tử")	Valid
	EC02	Chuỗi rỗng ($length = 0$)	Invalid
	EC03	Chuỗi chỉ chứa toàn khoảng trắng (`" "`)	Invalid
	EC04	Tên danh mục có độ dài vượt biên trên ($length > 255$)	Invalid
	EC05	Chuỗi chứa mã độc HTML / XSS (`<script>alert(1)</script>`)	Invalid
Quyền truy cập (`role`)	**EC06**	Tài khoản có `role = 'admin'` với Token hợp lệ	Valid
	EC07	Tài khoản có `role = 'user'` (Người dùng thường)	Invalid
	EC08	Không có Token / Token không hợp lệ (Khách vãng lai)	Invalid
ID Danh mục khi Xóa (`id`)	**EC09**	ID tồn tại trong CSDL và chưa có sản phẩm liên kết	Valid
	EC10	ID tồn tại nhưng đang có sản phẩm liên kết (Ràng buộc toàn vẹn)	Invalid
	EC11	ID không tồn tại trong CSDL	Invalid
Hộp thoại xác nhận (`dialog`)	**EC12**	Có Modal xác nhận nguy hiểm trước khi xóa (FR-24)	Valid
	EC13	Không có Modal xác nhận nguy hiểm (Xóa trực tiếp)	Invalid

3. Phân tích Giá trị Biên (Boundary Value Analysis - BVA)

Biên độ dài tên danh mục: $LB = 1$ ký tự, $UB = 255$ ký tự (chuẩn độ dài cột chuỗi).

- $LB - 1 = 0$: Chuỗi rỗng `""` (Điểm OFF - Invalid: Hệ thống PHẢI từ chối).
- $LB = 1$: Chuỗi 1 ký tự `"A"` (Điểm ON - Valid: Độ dài tối thiểu hợp lệ).
- $LB + 1 = 2$: Chuỗi 2 ký tự `"Ao"` (Điểm IN - Valid).
- $Nominal = 14$: Tên danh mục thông thường `"Thời trang Nam"` (Valid).
- $UB = 255$: Chuỗi 255 ký tự (Valid).
- $UB + 1 = 256$: Chuỗi 256 ký tự (Invalid nếu có giới hạn độ dài).

STT	Điểm biên	Giá trị kiểm thử (`name`)	Dự kiến (Expected Output)
BV01	$LB - 1$	`""` (0 ký tự)	Invalid (Báo lỗi: Tên danh mục không được để trống)
BV02	LB	`"A"` (1 ký tự)	Valid (Tạo danh mục thành công)
BV03	$LB + 1$	`"Ao"` (2 ký tự)	Valid (Tạo danh mục thành công)
BV04	Nom	`"Thời trang Nam"`	Valid (Tạo danh mục thành công)
BV05	UB	Chuỗi 255 ký tự	Valid (Tạo danh mục thành công)
BV06	$UB + 1$	Chuỗi 256 ký tự	Invalid (Báo lỗi hoặc chặn nhập)

4. Kiểm thử Miền Phân quyền & Tính toàn vẹn (Authorization Domain)

Thiết lập ma trận kiểm thử quyền thao tác trên danh mục (12 luật $R_1 \to R_{12}$):

Mã luật	Vai trò người dùng (Role)	Thao tác CRUD	Endpoint & Method	Dữ liệu gửi kèm	Kết quả kỳ vọng theo SRS	Mã HTTP kỳ vọng
R1	admin	**CREATE**	POST /api/categories	{"name": "Gia dụng"}	Tạo danh mục thành công, cấp ID mới	**200 / 201**
R2	admin	**READ**	GET /api/categories	None	Trả về danh sách tất cả danh mục	**200 OK**
R3	admin	**UPDATE**	PUT /api/categories/1	{"name": "Gia dụng mới"}	Cập nhật tên danh mục thành công	**200 OK**
R4	admin	**DELETE**	DELETE /api/categories/1	None (ID không có SP)	Xóa danh mục thành công khỏi CSDL	**200 OK**
R5	user	**READ**	GET /api/categories	None	Trả về danh sách danh mục để mua sắm	**200 OK**
R6	user	**CREATE**	POST /api/categories	{"name": "Hack Category"}	**BỊ TỪ CHỐI.** Báo lỗi không có quyền Admin	**403 Forbidden**
R7	user	**UPDATE**	PUT /api/categories/1	{"name": "Tamper Name"}	**BỊ TỪ CHỐI.** Báo lỗi không có quyền Admin	**403 Forbidden**
R8	user	**DELETE**	DELETE /api/categories/1	None	**BỊ TỪ CHỐI.** Báo lỗi không có quyền Admin	**403 Forbidden**
R9	guest	**READ**	GET /api/categories	None	Trả về danh sách danh mục	**200 OK**
R10	guest	**CREATE**	POST /api/categories	{"name": "Guest Category"}	**BỊ TỪ CHỐI.** Yêu cầu đăng nhập	**401 Unauthorized**
R11	guest	**UPDATE**	PUT /api/categories/1	{"name": "Guest Update"}	**BỊ TỪ CHỐI.** Yêu cầu đăng nhập	**401 Unauthorized**
R12	guest	**DELETE**	DELETE /api/categories/1	None	**BỊ TỪ CHỐI.** Yêu cầu đăng nhập	**401 Unauthorized**

5. Thiết kế Bộ Ca Kiểm thử & Kết quả Thực thi trên SUT

Toàn bộ 12 ca kiểm thử được thực thi trực tiếp trên hệ thống SUT Live (Web Admin `http://localhost:5174` và Backend API `http://localhost:3000`):

#TC	Tên / Mục tiêu kiểm thử	Lớp tương đương / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế (Actual trên SUT)	Trạng thái (Pass/Fail)	Mã Lỗi (Bug ID)
TC-CAT-01	Tạo danh mục tên hợp lệ tại biên dưới ($LB = 1$)	EC01, BV02, EC06, R1	• Role: `admin` • `name`: `"A"`	HTTP 200/201 OK. Lưu danh mục "A" vào DB.	Tạo thành công danh mục "A" trong SQLite.	**PASS**	—
TC-CAT-02	Tạo danh mục độ dài danh định ($Nom = 14$)	EC01, BV04, EC06, R1	• Role: `admin` • `name`: `"Thời trang Nam"`	HTTP 200/201 OK. Tạo thành công.	Tạo thành công danh mục "Thời trang Nam".	**PASS**	—
TC-CAT-03	Tạo danh mục độ dài tối đa tại biên trên ($UB = 255$)	EC01, BV05, EC06, R1	• Role: `admin` • `name`: `'C'.repeat(255)`	HTTP 200/201 OK. Lưu đủ 255 ký tự không cắt xén.	CSDL lưu trọn vẹn chuỗi 255 ký tự.	**PASS**	—
TC-CAT-04	Kiểm tra từ chối khi tạo danh mục tên rỗng ($LB - 1 = 0$)	EC02, BV01, EC06	• Role: `admin` • `name`: `""`	**BỊ TỪ CHỐI.** Form chặn (`required`) hoặc API trả về HTTP 400.	**LỖI:** Không validate $\implies$ Backend trả về 200 OK, tạo bản ghi rỗng trong CSDL!	**FAIL**	`BUG-FR14-01` (`BUG-08`)

#TC	Tên / Mục tiêu kiểm thử	Lớp tương đương / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế (Actual trên SUT)	Trạng thái (Pass/Fail)	Mã Lỗi (Bug ID)
TC-CAT-05	Kiểm tra từ chối khi tên chỉ chứa khoảng trắng	EC03, EC06	• Role: `admin` • `name`: `"  "` (3 dấu cách)	**BỊ TỪ CHỐI.** Hệ thống trim và trả về HTTP 400.	**LỖI:** Không trim, tạo thành công danh mục toàn khoảng trắng trong DB!	**FAIL**	BUG-FR14-01 (BUG-08)
TC-CAT-06	Kiểm tra từ chối khi độ dài vượt quá biên trên ($UB + 1 = 256$)	EC04, BV06, EC06	• Role: `admin` • `name`: `'D'.repeat(256)`	**BỊ TỪ CHỐI.** HTTP 400 hoặc ô input chặn nhập quá 255 ký tự.	**LỖI:** Không chặn độ dài $\implies$ Ghi nhận chuỗi 256 ký tự vào CSDL!	**FAIL**	BUG-FR14-01 (BUG-08)
TC-CAT-07	Kiểm tra phòng chống tấn công Stored XSS Script	EC05, EC06	• Role: `admin` • `name`: `<script>alert('XSS')</script>`	Tự động escape hoặc sanitize an toàn.	**CẢNH BÁO:** Backend lưu nguyên văn raw script vào CSDL mà không sanitize.	**FAIL**	BUG-FR14-01 (BUG-08)
TC-CAT-08	Kiểm soát phân quyền: User thường gọi API tạo danh mục	EC07, R6, SEC-03	• Role: `user` • `name`: `"Hack Category"`	**BỊ TỪ CHỐI.** Trả về HTTP 403 Forbidden.	**LỖI LEO QUYỀN (BOLA):** Middleware không kiểm tra `role === 'admin'`, cho phép User tạo danh mục!	**FAIL**	BUG-FR14-02 (BUG-09)

#TC	Tên / Mục tiêu kiểm thử	Lớp tương đương / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế (Actual trên SUT)	Trạng thái (Pass/Fail)	Mã Lỗi (Bug ID)
TC-CAT-09	Kiểm soát phân quyền: User thường gọi API xóa danh mục	EC07, R8, SEC-03	• Role: `user` • Target: `DELETE /api/categories/1`	**BỊ TỪ CHỐI.** Trả về HTTP 403 Forbidden.	**LỖI LEO QUYỀN (BOLA):** User thường xóa vĩnh viễn được danh mục của hệ thống!	**FAIL**	`BUG-FR14-02` (`BUG-09`)
TC-CAT-10	Xác thực danh tính: Khách vãng lai gọi API không có Token	EC08, R10, SEC-03	• Role: `guest` • Token: None	**BỊ TỪ CHỐI.** Trả về HTTP 401 Unauthorized.	Phản hồi đúng HTTP 401 Unauthorized. Chặn chính xác.	**PASS**	—
TC-CAT-11	Kiểm tra hộp thoại xác nhận khi xóa danh mục (FR-24)	EC12, EC13, FR-24	Bấm nút "Xóa" trên Web Admin	Bắt buộc hiển thị modal/dialog xác nhận nguy hiểm.	**LỖI:** Gọi thẳng API xóa ngay khi click, không có modal xác nhận!	**FAIL**	`BUG-FR14-03` (`BUG-10`)

#TC	Tên / Mục tiêu kiểm thử	Lớp tương đương / Điểm biên	Dữ liệu đầu vào (Test Data)	Kết quả kỳ vọng (Expected)	Kết quả thực tế (Actual trên SUT)	Trạng thái (Pass/Fail)	Mã Lỗi (Bug ID)
TC-CAT-12	Ràng buộc toàn vẹn: Ngăn chặn xóa danh mục có sản phẩm liên kết	EC10, Data Integrity	Xóa danh mục có ID đang gắn với sản phẩm	**BỊ TỪ CHỐI.** Chặn xóa (HTTP 400 hoặc 409) bảo vệ quan hệ FK.	**LỖI TOÀN VẸN CSDL:** Xóa thẳng không kiểm tra khóa ngoại, biến sản phẩm thành mồ côi!	**FAIL**	`BUG-FR14-03` (`BUG-10`)

Bảng Thống kê Kết quả Kiểm thử FR-14:

- **Tổng số ca kiểm thử thiết kế & thực thi:** 12 ca (100.0%)
- **Số ca ĐẠT (PASS):** 4 ca (33.3%)
- **Số ca KHÔNG ĐẠT (FAIL):** 8 ca (66.7%)
- **Tổng số Bugs phát hiện:** 3 Bugs (`BUG-FR14-01`, `BUG-FR14-02`, `BUG-FR14-03`)

6. Phân tích Thiếu sót của AI (AI Gap Analysis)

6.1 Những điểm AI bỏ sót khi sinh kiểm thử Quản lý Danh mục:

1. **Bỏ sót lỗ hổng leo quyền (Privilege Escalation - SEC-03):** AI thường mặc định kiểm tra API Admin bằng tài khoản Admin, do đó không bao giờ phát hiện ra middleware `authenticateToken` bị thiếu bước kiểm tra `req.user.role === 'admin'`.
2. **Bỏ sót lỗi biên chuỗi rỗng ($length = 0$) do thiếu ràng buộc CSDL:** Cả giao diện (thiếu thuộc tính `required`) và Backend (thiếu lệnh `if (!name) return 400`) đều không kiểm tra chuỗi rỗng, kết hợp CSDL SQLite không có `NOT NULL`, dẫn tới việc tạo ra dữ liệu rác.
3. **Bỏ sót kiểm tra toàn vẹn quan hệ (Foreign Key Integrity):** AI thường test từng bảng riêng rẽ mà bỏ qua mối quan hệ 1-N giữa Category và Product.

7. Minh chứng Kiểm thử (Defect Evidence & Screenshots)

Toàn bộ minh chứng được lưu trữ tại thư mục `screenshots/F14/` gồm các ảnh chụp mã lỗi (VS Code IDE Code Card) và thực tế giao diện / CSDL:

Mã Bug	Tên Lỗi Phát Hiện	Minh Chứng Mã Lỗi (VS Code IDE)	Minh Chứng Thực Tế (UI / CSDL)

Mã Bug	Tên Lỗi Phát Hiện	Minh Chứng Mã Lỗi (VS Code IDE)	Minh Chứng Thực Tế (UI / CSDL)
BUG-FR14-01 (BUG-08)	Tạo danh mục tên rỗng ($LB-1$) & khoảng trắng	[BUG-FR14-01_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-01_Code.png)	[BUG-FR14-01_UI.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-01_UI.png)
BUG-FR14-02 (BUG-09)	Lỗ hổng leo quyền BOLA (User tạo/xóa category)	[BUG-FR14-02_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-02_Code.png)	[BUG-FR14-02_UI.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-02_UI.png)
BUG-FR14-03 (BUG-10)	Thiếu dialog xác nhận xóa & Mồ côi dữ liệu CSDL	[BUG-FR14-03_Code.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-03_Code.png)	[BUG-FR14-03_UI.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-03_UI.png) [BUG-FR14-03_DB.png] (file:///d:/KAN/N4_1/KTPM-2026-HW02-Domain-Testing/screenshots/F14/BUG-FR14-03_DB.png)

> **Ghi chú về quy ước đặt tên:** Toàn bộ tệp hình ảnh được chuẩn hóa đồng nhất theo mã phân hệ tương tự F01 và F09:
>
> - `BUG-FR14-01_*.png` (tương ứng `BUG-08` trong Báo cáo Tổng hợp).
> - `BUG-FR14-02_*.png` (tương ứng `BUG-09` trong Báo cáo Tổng hợp).
> - `BUG-FR14-03_*.png` (tương ứng `BUG-10` trong Báo cáo Tổng hợp).
> - Các ảnh chụp thô quá trình test (`TC04` $\to$ `TC12`) được lưu giữ tại thư mục `screenshots/F14/raw_test_cases/`.